CHAROTAR UNIVERSITY OF SCIENCE AND TECHNOLOGY (CHARUSAT)

CSPIT — Department of Computer Engineering · ITUE203 Web Development Frameworks

Student Name	Dhruv Bhoi	**Student ID**	**D26CE154**
Academic Year	2026–27 (ODD)	**Semester**	3rd Semester, B.Tech CE

Practical 9: Secure User Registration with Database Insert, Duplicate Email Check, and Password Hashing

Practical Aim & Tools

Aim: Build secure user registration with server-side validation, duplicate email check, bcrypt password hashing (`password_hash`), database transactions, and audit logging.

Tools & Technologies: PHP 8.x, MySQLi Prepared Statements, Bcrypt Algorithm, ACID Database Transactions

1. Secure Registration Workflow & Threat Mitigation

User registration (`register.php`) establishes student identities securely through five defensive layers:

1. Server Validation: Re-executes all pattern validations independently of frontend checks.
2. Duplicate Check: Executes a parameterized SELECT query to verify email uniqueness before attempting insertion.
3. Cryptographic Hashing: Generates secure Bcrypt salted hashes using `password_hash($password, PASSWORD_DEFAULT)` with default cost factor 10.
4. Database Transactions: Wraps `users` insert and `students` insert within `$mysqli->begin_transaction()`. If either fails, `$mysqli->rollback()` ensures zero orphaned records.
5. Security Audit Log: Records registration event, user ID, client IP address, and timestamp into `audit_logs`.

2. Implementation Code: Transactional Registration

Listing: register.php — Atomic ACID Registration with Bcrypt Hashing

```
// register.php - Transactional Registration
$hash = password_hash($d['password'], PASSWORD_DEFAULT);
$mysqli->begin_transaction();
try {
    $u = $mysqli->prepare('INSERT INTO users (name, email, password_hash, role) VALUES (?, ?, ?,
?)');
    $role = 'student';
    $u->bind_param('ssss', $old['name'], $d['email'], $hash, $role);
    $u->execute();
    $uid = $mysqli->insert_id;
```

```
    $s = $mysqli->prepare('INSERT INTO students (user_id, name, email, mobile, course, year,
gender) VALUES (?, ?, ?, ?, ?, ?, ?)');
    $s->bind_param('issssis', $uid, $old['name'], $d['email'], $d['mobile'], $d['course'],
$d['year'], $d['gender']);
    $s->execute();

    $mysqli->commit();
    flash('success', 'Registration successful! You may now log in.');
    redirect('login.php');
} catch (Exception $e) {
    $mysqli->rollback();
    $errors['form'] = 'Registration failed. Please try again.';
}
```

3. Verification Screenshot: Registration Form & Error States

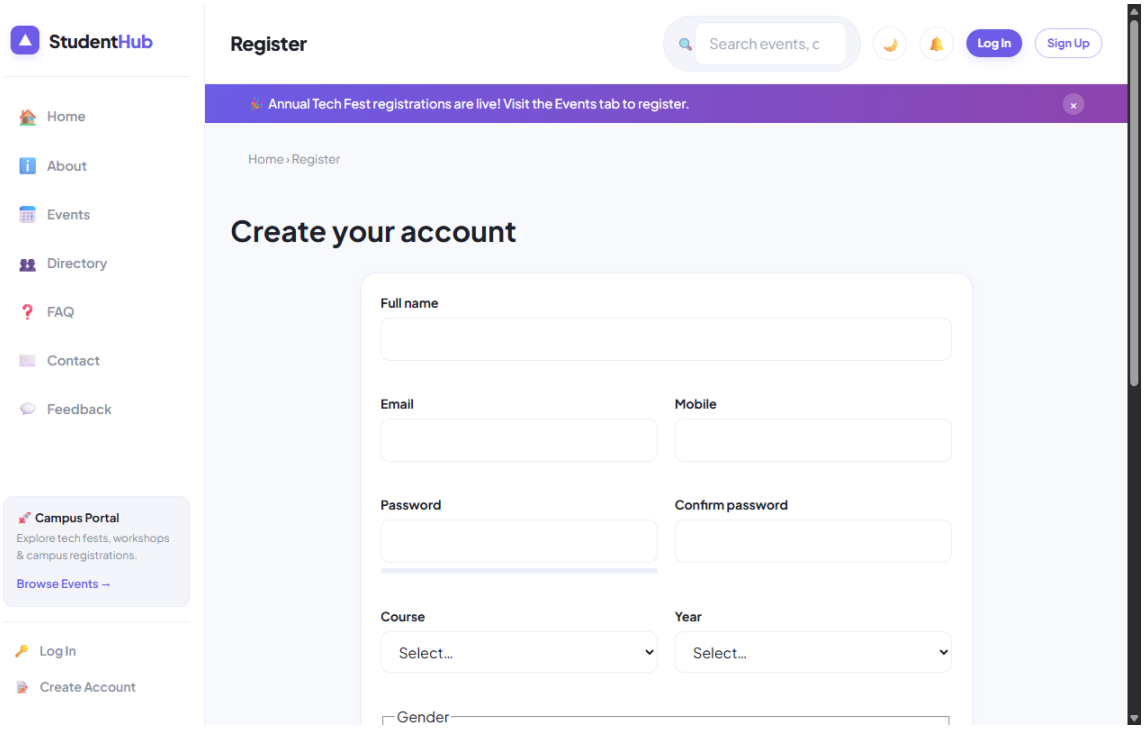


Figure: Registration Form Demonstrating Validation Cues and Account Creation

4. Key Questions & Analysis

Q: Why should MD5 or SHA1 never be used for password storage?

Ans: MD5 and SHA-1 are high-speed general hashing algorithms that lack computational work factors. Modern GPUs compute billions of MD5 hashes per second, making rainbow table and brute-force attacks trivial. Bcrypt incorporates an adaptive slow cost factor and automatic random salt generation.

Q: How does the system prevent duplicate account registrations?

Ans: Through a two-step defense: 1) A parameterized SQL query verifies if the email exists prior to hashing, and 2) A database-level `UNIQUE KEY (email)` constraint on the `users` table acts as a failsafe, catching race conditions via SQL exception code 1062.

Practical 9 Conclusion & Learning Outcomes

Engineered an enterprise user registration pipeline featuring server-side regex validation, duplicate email verification queries, cryptographically secure Bcrypt password hashing (password_hash), and ACID database transactions with rollback capabilities.